ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Schneider Electric EcoStruxure Power SCADA Operation / Power Operation (PSO/PO, Citect-based) · Component type: **Software Application (SAR) - power management SCADA/HMI software** · Target SL = SL 3

Where to work	**Power SCADA Studio / Citect Studio** (project config, users, roles/privileges, areas); **Power Operation Web Applications** (HTML5 "Power SCADA Anywhere"); the runtime **Citect Explorer / Runtime Manager**; config in **Citect.ini** (e.g. [Client]AutoLoginMode) and **configuration.xml** (Windows Groups › privilege mapping). Devices via **OFS / OPC UA** and native drivers. Installer from Schneider (signed).
Ports / paths	**HTTPS 443 / HTTP 80** (Web Applications - HTTP off); Citect **client-server TCP (~2073-2080)** (enable TLS/encryption); **OPC UA 4840** / OFS DCOM (RPC 135); device protocols **Modbus 502**, **DNP3 20000**, **IEC 61850 MMS 102**, **IEC 60870-5-104 2404**; NTP 123; Syslog 514. Project files (compiled), Citect.ini, configuration.xml on the host.
Notes	SAR - Schneider EcoStruxure Power SCADA Operation / Power Operation (Citect-based power SCADA). Confirm version (PSO 9.0 / PO 2020/2022/2024) and patch level (Schneider SEVD / CISA advisories). Schneider certifies PSO to **IEC 62443-4-2 SL2**; for SL-3 verify each control and record compensating controls where the native capability stops at SL2.
How to read	Each row = native step-by-step (Studio / Web Apps / Citect.ini) + command-level external-tool steps. Default read-only (review users/roles, .ini, config exports, screenshots). Mark Pass/Fail/Partial/N/A. Write/exploit tools = isolated env + written authorization.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	Confirm every access path authenticates: the runtime clients, **Power Operation Web Applications**, and Studio require login. Prefer **Windows Active Directory** integration (AD groups mapped to Power Operation privileges in **configuration.xml**); ensure **auto-login is off** - check [Client]AutoLoginMode in Citect.ini is not set to bypass login. No anonymous runtime/web access. **Test:** open a runtime client / the Web App without credentials -> login required; confirm AutoLoginMode does not silently log in a privileged user. **Ext. tools:** Studio (user list); Citect.ini (AutoLoginMode); browse the Web App logged-out -> login prompt; `nmap -p 80,443 <host>`.	All clients/Web/Studio authenticate; AD-integrated where possible; no auto-login/anonymous path.	
SR/CR 1.2	Software process / device identification	Confirm server-to-server (redundant primary/standby, I/O servers) and device connections are identified/authenticated: OFS/OPC UA endpoints by certificate; device drivers bound to known IPs; the Citect cluster members are defined. **Ext. tools:** Studio (cluster/servers, I/O devices); OPC UA client (endpoint/cert); Wireshark (partner IPs).	Cluster/server + device identities defined; OPC UA cert-bound where used.	
SR/CR 1.3	Account management	Review Power Operation user accounts + **privilege levels 1-8** and their mapping to Web-App roles (e.g. Priv3 = access level 3 / Controller); manage via AD groups where integrated. Remove/rename defaults, least privilege, no shared logins. **Ext. tools:** Studio (users/roles); configuration.xml (Windows-Group -> privilege map); AD group review.	Named least-privilege accounts/roles; defaults removed; AD-managed where used.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers (AD/Power Operation) and unique server/cluster identities; no reuse. **Ext. tools:** Studio (users/servers); AD; host inventory.	Unique user and server identifiers; no reuse.	
SR/CR 1.5	Authenticator management	For AD-integrated users, password policy is enforced by **AD** (capture evidence). For any local Citect users, set strong passwords + change defaults. Manage TLS certs/keys. Consider MFA at the AD/SSO layer. **Ext. tools:** AD password policy (gpresult); Studio (local user review); confirm defaults changed.	Strong password policy (AD or local); defaults changed; MFA where feasible.	
SR 1.6	Wireless access management	**N/A.** Software application with no wireless interface; wireless is a host/network concern. **Ext. tools:** Confirm no device wireless; host WLAN governed by OS/network.	N/A - justification recorded (software).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	For the **Web Applications** (HTTPS), **SSO**, and Citect client-server encryption/OPC UA, confirm CA-signed certificates (not default self-signed), valid, strong keys (>=2048 RSA/ECC); TLS 1.2/1.3. **Ext. tools:** `testssl.sh https://<host>`; `openssl s_client -connect <host>:443`; OPC UA client (policy/cert).	CA-signed certs for Web/SSO/OPC UA; strong keys/TLS; defaults replaced.	
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm the runtime, Web App, and Studio logins mask password entry (no cleartext echo). **Ext. tools:** Visual verification at each interface.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	For AD users, lockout is enforced by AD (verify policy). Confirm the Web App / runtime lock/throttle repeated failures and log them; where native lockout is limited, compensate with AD + a reverse-proxy/WAF for the web tier. **Ext. tools:** AD lockout policy; Web-App failed-login behavior; Hydra (ISOLATED, authorized) to characterize.	Lockout via AD/proxy; failures logged; native gap recorded if any.	
SR/CR 1.12	System use notification	Configure a use-notification banner on the runtime/Web-App login where supported; enforce it on the Windows host (GPO logon banner) as a compensating control. **Ext. tools:** Runtime/Web login screenshot; host `gpresult /h gp.html`.	Approved use notice at login/host.	
SR 1.13	Access via untrusted networks	Confirm the PSO servers + Web tier are reachable only from the trusted OT/DMZ zone; the Web Applications are fronted by a reverse proxy in the DMZ with MFA; Citect client-server + OFS not exposed to untrusted networks; remote access via VPN/jump host. **Test:** from an untrusted VLAN, reach 443 / the Citect ports -> must fail. **Ext. tools:** `nmap -Pn -p 80,443,2073-2080,135,4840 <host>` from the untrusted side (expect filtered); firewall review.	PSO/Web unreachable from untrusted networks; remote via VPN + MFA.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Confirm least privilege via **privilege levels 1-8** + **areas**: a user only sees/controls the areas and command levels granted; a low-privilege operator cannot acknowledge/override or change configuration. Web-App roles mirror the Citect privileges. **Test:** as a low-privilege user, attempt a control/config action outside the granted area/level -> denied. **Ext. tools:** Studio (privilege/area matrix); low-privilege negative test in the runtime/Web App.	Least privilege by level + area enforced; negative test confirms denial.	
SR/CR 2.2	Wireless use control	**N/A.** Software application, no wireless interface. **Ext. tools:** Confirm no wireless; host/network layer governs.	N/A - justification recorded.	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control the engineering/operator workstations and removable media (host device-control); only authorized project files and installers loaded; restrict who runs Studio. **Ext. tools:** Host removable-media GPO; confirm project/installer provenance.	Portable/engineering media controlled.	
SR/SAR 2.4	Mobile code	Control mobile/embedded code: restrict **Cicode** / scripting and any Web-App custom content to trusted, reviewed project resources; only signed Schneider components/drivers installed; sandbox any embedded browser. **Ext. tools:** Studio (Cicode/scripts review); installed-component signature review.	Only signed/required components; Cicode restricted; no untrusted code.	SAR-specific.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.5	Session lock	Confirm runtime/Web-App inactivity timeout (auto-logoff) and the host OS screen lock; a locked session requires re-authentication. **Ext. tools:** Runtime/Web inactivity-timeout config; host inactivity-lock GPO.	Sessions lock/log off on inactivity; re-auth required.	
SR/CR 2.6	Remote session termination	Confirm active runtime/Web sessions can be viewed/terminated and idle sessions close; concurrent sessions are bounded/monitored (licensing + server config). **Ext. tools:** Runtime Manager / Web-App session review; Wireshark (session teardown).	Sessions terminable; concurrency bounded/monitored.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	Confirm the **event/alarm log** records security-relevant actions (login, control/command, ack, config change) with the acting user, and is forwarded via **Syslog** to the SIEM. Per-user accounts give attribution; the "who did what" is captured. **Test:** perform a control action -> an event-log/Syslog entry with user + action + time. **Ext. tools:** Runtime event log; `nc -lu 514` / SIEM; trigger a test action.	Security actions logged with attribution and forwarded to the SIEM.	
SR/CR 2.9	Audit storage capacity	Confirm the event/alarm log is sized/rotated and offloaded to the SIEM, with alerting if forwarding fails so events are not silently lost. **Ext. tools:** Log sizing config; SIEM source-silent alert.	Logs sized/offloaded; audit-failure alerting defined.	
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the PSO servers + clients are NTP-synced so event/alarm and SIEM timestamps are accurate and correlate (critical for power-event sequence-of-events). **Ext. tools:** `w32tm /query /status`; Wireshark `ntp`.	Accurate, synchronized timestamps (SOE-grade).	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	Enable **TLS/encryption** on the Citect client-server links and **HTTPS** on the Web Applications (disable HTTP); secure OPC UA (sign+encrypt) to OFS/devices; keep cleartext device protocols (Modbus/DNP3/61850) contained in the segmented zone. **Test:** confirm client-server + web are encrypted, not cleartext. **Ext. tools:** Wireshark (TLS on Citect/web; OPC UA encrypted); `testssl.sh https://<host>`; `nmap -p 80 <host>` (HTTP off).	Client-server + Web TLS-protected; OPC UA secured; cleartext device protocols contained.	
SR/SAR 3.2	Protection from malicious code (component)	Confirm software integrity: install only the Schneider-**signed** PSO/Power Operation (verify the installer signature / download from Schneider); host anti-malware / **application whitelisting** (Schneider recommends McAfee/whitelisting) with PSO-aware exclusions; restrict install/upgrade to admins. **Ext. tools:** `signtool verify /pa <setup>.exe`; host AV/whitelisting; installed-component review.	Signed software validated; whitelisting active; install restricted.	SAR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: AD integration/no-auto-login, privilege/area matrix, TLS on client-server + Web, OPC UA security, syslog, and patch level, against the PSO cybersecurity-guide baseline; compare the project + Citect.ini/configuration.xml. **Ext. tools:** Studio compare; diff Citect.ini/configuration.xml vs baseline; `nmap -p 80,443 <host>`.	Security settings match the hardening baseline after change.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.4	Software & information integrity	Protect the project + config: back up the compiled project, Citect.ini, and configuration.xml (versioned, offline); protect them with host ACLs; use change detection so unauthorized project/config change is detected; secrets not stored in plaintext. **Ext. tools:** Host ACL on the project/ini/xml; `certutil -hashfile project SHA256` for drift; backup review.	Project/config integrity protected; unauthorized change detected.	
SR/CR 3.5	Input validation	Confirm the Web Applications / any REST endpoints validate input and the Cicode/named-query paths are not injectable; patch known PSO/Citect CVEs. **ISOLATED:** test the web tier. **Ext. tools:** Burp/ZAP against the Web App (ISOLATED); Nessus/OpenVAS for known CVEs; Schneider SEVD cross-check.	Inputs validated; known CVEs patched; no injectable path.	SAR-specific.
SR/CR 3.6	Deterministic output	**N/A.** SCADA software does not directly drive a physical output; deterministic/fail-safe output is a device-layer control. Confirm command-confirmation (select-before-operate) and comms-loss quality handling to operators. **Ext. tools:** Confirm SBO/command-confirm and Bad-quality display on comms loss; no direct process output from PSO.	N/A - justification recorded (software application).	N/A
SR/CR 3.7	Error handling	Confirm errors/diagnostics are handled gracefully without leaking sensitive info; review the syslog/hardware-alarm and Cicode error handling; no plaintext secrets in logs. **Ext. tools:** Runtime hardware alarms / logs review; log-content check.	Graceful error handling; no info leak.	
SR/CR 3.8	Session integrity	Confirm runtime/Web/OPC-UA sessions are integrity-protected (TLS) against replay/hijack; no unauthenticated/cleartext session path remains (HTTP/unencrypted Citect off). **Ext. tools:** Wireshark (session inspection).	Sessions integrity-protected; no unauthenticated path.	
SR/CR 3.9	Protection of audit information	Protect the event/alarm log + Syslog transport (Syslog-over-TLS where supported) and the SIEM store; restrict who can read/clear the logs (privilege-gated + host ACLs). **Ext. tools:** Studio (log-access privilege); SIEM access review; syslog transport.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, remove the project, Citect.ini/configuration.xml, credentials, certificates, historical/event data, and backups; confirm no plaintext secrets persist; encrypt the host disk. **Ext. tools:** grep config/exports for secrets; confirm project/data/backups removed; BitLocker status.	Secrets/project/data/certs purged on decommission; disk encrypted.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto: TLS 1.2/1.3 on Web/client-server, OPC UA Basic256Sha256, CA-signed certs; disable weak/legacy protocols and cleartext services. **Ext. tools:** `testssl.sh https://<host>`; OPC UA policy; Wireshark.	Modern crypto in use; weak/legacy protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Confirm the PSO servers sit in a controlled OT zone; the Web tier is fronted by a reverse proxy in the IDMZ; only required flows cross (HTTPS, Citect client-server, OFS/OPC UA, device protocols) to authorized peers; no flat convergence with IT. **Ext. tools:** `nmap -p 80,443,2073-2080,135,4840,502,20000,102,2404 <host>` per zone; firewall + IDMZ review.	PSO in a segmented zone; Web via IDMZ proxy; only required flows cross.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** SCADA platform with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	Partition by criticality: separate clusters/areas and least-privilege roles per function; where trust levels differ, separate servers/zones (e.g. view-only vs control). **Ext. tools:** Studio (cluster/area/role segregation); server topology vs criticality.	Applications/areas partitioned by criticality.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm the event/alarm log is readable/exportable by authorized staff and forwarded (Syslog) to the SIEM; monitor server/redundancy health and the host; passive OT IDS on the segment. **Ext. tools:** Runtime log export; Syslog + SIEM; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial-of-service protection	Confirm resilience: **redundant primary/standby servers** + I/O server redundancy provide availability; the Web tier/reverse proxy rate-limits; host resource limits; do not co-host unrelated apps. Boundary controls bound floods. **Ext. tools:** Studio (redundancy config); ISOLATED load/soak test; host resource monitor.	Redundant servers + rate-limiting keep SCADA available under load.	
SR/CR 7.2	Resource management	Confirm bounded resource use (server/session/connection limits, tag/license limits) so a flood cannot exhaust the runtime; monitor CPU/mem. **Ext. tools:** Runtime resource counters; host monitor; bench load test.	Resources bounded; no exhaustion-based loss of service.	
SR/CR 7.3	Control system backup	Confirm the project, Citect.ini/configuration.xml, certificates, and historical data are backed up (versioned, offline) and a restore + **redundancy failover** is tested on a spare/standby for a known-good rebuild. **Ext. tools:** Backup repository; restore test (lab); redundancy failover test.	Backups current; restore + failover validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden per the PSO cybersecurity guide: AD integration + no auto-login, TLS everywhere + HTTP off, disable unused drivers/protocols/services, application whitelisting, least-privilege service account, keep PSO patched, remove sample/demo projects. **Ext. tools:** Studio/Citect.ini review; installed-driver review; `nmap -sTU -p- <host>` (only required open); version vs current.	Least functionality; unused services disabled; patched per the guide.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the PSO/Power Operation version + build, installed drivers/OFS, and the OS so vulnerabilities track against Schneider SEVD / CISA advisories (e.g. ICSA-25-224-03). **Ext. tools:** Help › About / installed components; Schneider SEVD feed; passive OT IDS inventory.	Accurate version/component inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Power SCADA Studio / Citect Studio	Native config & security review (all FRs)	Review users, privilege levels 1-8 + area mapping to Web-App roles, cluster/redundancy, drivers, Cicode; export the project as the baseline.	Read/authorized project copy.
Citect.ini / configuration.xml	Login & AD-mapping review (1.1, 1.3, 3.3)	Confirm [Client]AutoLoginMode does not bypass login; review the Windows-Group -> Power Operation privilege map.	Read-only; host ACL.
Power Operation Web Applications (browser)	Web access, roles & TLS (1.1, 1.8, 2.1)	Confirm login required, HTTPS with a managed cert, and role-based access; front with a DMZ reverse proxy.	Read-only; authorized.
signtool	Signed-installer validation (SAR 3.2)	`signtool verify /pa <setup>.exe` or Properties › Digital Signatures; download from Schneider.	Read-only.
nmap	Port/service exposure & segmentation (1.13, 5.x, 7.6)	`nmap -p 80,443,2073-2080,135,4840,502,20000,102,2404 <host>`; scan per zone; confirm HTTP/unused closed.	Read-only; authorized.
testssl.sh / openssl	TLS on Web / client-server (1.8, 3.1, 4.3)	`testssl.sh https://<host>`; `openssl s_client -connect <host>:443`; confirm TLS1.2/1.3, strong ciphers, CA-signed.	Non-intrusive.
Wireshark / tcpdump	Comms integrity (3.1, 3.8, 2.11)	SPAN/tap; confirm Citect client-server + Web are TLS, OPC UA encrypted, device protocols contained in-zone; inspect NTP.	Passive; SPAN/tap only.
OPC UA client / Syslog+SIEM	OPC UA security & audit (1.2, 3.1, 2.8, 6.x)	Check OFS/OPC UA endpoint policy/cert; confirm PSO forwards event/alarm syslog; trigger a test action.	Read-only; coordinate with SIEM.
Burp / ZAP / Nessus / OpenVAS + Schneider SEVD	Web validation & CVE scan (3.5, 7.8)	Proxy the Web App to test authz/input (ISOLATED); scan for known PSO/Citect CVEs; cross-check Schneider SEVD / CISA.	ISOLATED/representative; authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.